

Cryptanium Security Audit Report

Repository: venkatesh-99-cbs/Cryptanium | Branch: main | Language: Python | Scan Date: 2026-07-20 10:07:09 UTC

1. Executive Summary

Repository Overview:	Repository 'venkatesh-99-cbs/Cryptanium' on branch 'main' is written primarily in Python. Automated security scans analyzed code artifacts and identified a total of 5 findings.
Security Posture:	The repository achieved a Trust Score of 23.5/100, placing it in the 'Critical' risk tier. Scoring deductions reflect base severity findings and safety rules.
Key Security Findings:	The audit detected 1 Critical and 1 High severity vulnerabilities. Notable issues: [Critical] Possible SQL injection in dynamic query construction (backend/app/main.py); [High] Exposed OpenRouter API Key detected in codebase (backend/.env).
Deployment Readiness:	NOT READY FOR DEPLOYMENT. Critical or high-severity vulnerabilities must be remediated prior to staging or production releases.

2. Trust Score & Risk Level Analysis

23.5 / 100 Critical Risk	Rule Applied	Deduction	Details / Reason
	SeverityDeductionRule	-51.5 pts	Deducted 51.5 points across findings: 1 Critical, 1 High, 1 Medium, 1 Low, 1 Info
	SecretExposurePenaltyRule	-15.0 pts	Detected 1 exposed secrets. Penalty: 15.0 pts
	VulnerableDependencyPenaltyRule	-10.0 pts	Detected 1 vulnerable dependencies. Penalty: 10.0 pts
	FindingVolumePenaltyRule	0.0 pts	Total findings count (5) within normal threshold.
	MissingDocumentationPenaltyRule	0.0 pts	SECURITY.md present.

3. OWASP Top 10 Category Mapping

OWASP Category	Findings Count
A03:2021 - Injection	1
A07:2021 - Identification and Authentication Failures	1
A06:2021 - Vulnerable and Outdated Components	1
A02:2021 - Cryptographic Failures	1
A05:2021 - Security Misconfiguration	1

4. Security Findings Matrix

Sev	Tool	Location	Description	OWASP
Critical	Bandit	backend/app/main.py:52	Possible SQL injection in dynamic query construction	A03
High	Gitleaks	backend/.env:8	Exposed OpenRouter API Key detected in codebase	A07
Medium	Trivy	backend/requirements.t...	Outdated urllib3 library vulnerable to ReDoS CVE-2023-45803	A06
Low	Bandit	backend/utlis/formatte...	Standard pseudo-random generator (random) used for non-cryptographic purpose	A02
Info	Semgrep	Dockerfile:2	Base image tag 'latest' used instead of fixed version pin	A05

5. Prioritized Remediation Action Plan

Priority	Issue	Recommended Fix	Security Reason
Urgent	Possible SQL injection in dynamic query construction (backend/app/main.py:52)	Use parameterized queries or SQLAlchemy ORM methods.	Fixing this Critical severity issue addresses potential security risk tagged under A03.
High	Exposed OpenRouter API Key detected in codebase (backend/.env:8)	Revoke API key immediately and add .env to .gitignore.	Fixing this High severity issue addresses potential security risk tagged under A07.
Medium	Outdated urllib3 library vulnerable to ReDoS CVE-2023-45803 (backend/requirements.txt:14)	Upgrade urllib3 to version >= 2.0.7	Fixing this Medium severity issue addresses potential security risk tagged under A06.
Low	Standard pseudo-random generator (random) used for non-cryptographic purpose (backend/utlis/formatter.py: 88)	Use 'secrets' module for security-sensitive random numbers.	Fixing this Low severity issue addresses potential security risk tagged under A02.
Low	Base image tag 'latest' used instead of fixed version pin (Dockerfile:2)	Pin Docker base image to a specific version digest or tag.	Fixing this Info severity issue addresses potential security risk tagged under A05.